Contents

1 SOC-LIN-003 — Technical Implementation Guide **1**
- 1.1 1. Outcome and scope . . . 1
- 1.2 2. Reference laboratory . . . 1
- 1.3 3. Prerequisites and data contract . . . 2
- 1.4 4. Confirm sudo telemetry on the target . . . 2
- 1.5 5. Create the Elastic EQL rule . . . 3
- 1.6 6. Generate authorized test events . . . 4
- 1.7 7. Validate the detection and investigate . . . 4
- 1.8 8. Acceptance checklist . . . 5
- 1.9 9. Evidence and maintained artifacts . . . 5
- 1.10 10. Adaptation for training and client environments . . . 6
- 1.11 11. Source and verification status . . . 6

1 SOC-LIN-003 — Technical Implementation Guide

Failed sudo authentication followed by privileged-command activity
Project: Elastic SOC Homelab | **Version:** 1.0 | **Guide date:** 2026-11-10
Scope: Authorized laboratory reproduction | **Status:** Original detection functionally validated; end-to-end reproduction of this guide not independently retested

1.1 1. Outcome and scope

Implement an Elastic Security **Event Correlation (EQL)** rule that alerts when three sudo authentication-failure **log events** for the same Linux username and host are followed by a root-level sudo command-invocation event within ten minutes. Validate the event sequence and close the authorized test alert as **True Positive — Benign**.

Boundary: This is a detection deployment guide, *not* an installation guide for Elasticsearch, Kibana, Fleet Server, or the underlying VM/PKI infrastructure. Complete those prerequisites first. This guide intentionally excludes unsuccessful troubleshooting attempts.

1.2 2. Reference laboratory

Component	Verified reference value
SIEM	Elastic Security / Elasticsearch 9.5.5
Linux target	`ubuntu-soc-target`, Ubuntu Server 24.04.5 LTS
Test account	`cybersafe`
Target address (lab only)	`192.168.100.226`

Component	Verified reference value
Log source	`/var/log/auth.log`, Elastic Agent System integration
Dataset / data stream	`system.auth` / `logs-system.auth-default`
Detection	`SOC-LIN-003`, Event Correlation (EQL)
MITRE ATT&CK	TA0004 / T1548 / T1548.003

1.3 3. Prerequisites and data contract

1. Elasticsearch, Kibana, Fleet Server, and the Linux Elastic Agent are installed, connected, and healthy; the Agent policy includes **System** integration with Linux authentication log collection enabled.
2. `/var/log/auth.log` is readable by the configured collection mechanism; authentication events reach `logs-system.auth-default`.
3. The Kibana account can create and enable Elastic Security detection rules and review alerts.
4. Use a designated non-production test account with `sudo` permission and authorized access to a disposable Ubuntu VM. Do **not** test with real client credentials or against production systems.
5. Confirm available fields in **Kibana > Discover**, using data view/index `logs-system.auth-default`:

Failure event fields	Privileged-command event fields
`host.name`, `user.name`	`host.name`, `user.name`
`event.dataset: system.auth`	`event.dataset: system.auth`
`event.category: authentication`	`event.category: process`
`process.name: sudo`	`process.name: sudo`
`event.action: authentication_failure`	`event.type: start`
`event.outcome: failure`	`system.auth.sudo.user: root`
`system.auth.sudo.command` absent	`system.auth.sudo.command` populated

Acceptance gate: Both event types must exist with usable `host.name` and `user.name`. If mappings or field values differ in a new environment, adapt the rule to the verified telemetry rather than copying it blindly.

1.4 4. Confirm sudo telemetry on the target

Run the following on `ubuntu-soc-target` using the authorized test account:

```
hostname
id -un
sudo -k
```

In Kibana **Discover**, select `logs-system.auth-default`, set a time range that includes the test, and inspect recent sudo events. This establishes collection and field parsing before creating the correlation rule. No Elasticsearch credentials or enrollment tokens should be included in documentation.

1.5 5. Create the Elastic EQL rule

In **Kibana > Security > Rules > Detection rules > Create new rule**, select **Event Correlation (EQL)**. Use the following settings:

Parameter	Exact reference configuration
Rule name	`SOC-LIN-003 - Failed Sudo Authentication Followed by Privileged Command`
Rule type	Event Correlation (EQL)
Index	`logs-system.auth-default`
Severity	Medium
Risk score	47
Runs every	5 minutes
Additional look-back	6 minutes
Correlation maxspan	10 minutes (specified in EQL)
MITRE ATT&CK	Privilege Escalation TA0004; T1548; T1548.003
State	Enabled

Validated EQL query — paste without alteration into the EQL editor:

```
sequence by host.name, user.name with maxspan=10m
  [authentication where
    event.dataset == "system.auth" and
    process.name == "sudo" and
    event.action == "authentication_failure" and
    event.outcome == "failure" and
    system.auth.sudo.command == null
  ] with runs=3
  [process where
    event.dataset == "system.auth" and
    process.name == "sudo" and
    event.type == "start" and
    system.auth.sudo.user == "root" and
    system.auth.sudo.command != null and
    system.auth.sudo.command != "validate" and
    event.outcome != "failure"
  ]
```

The sequence uses `host.name` and `user.name` as its matching keys. Do not configure the Kibana **Required fields** UI as a substitute for EQL sequence grouping. Save and enable the rule. Verify that at least one scheduled execution reports **Succeeded** before testing.

1.6 6. Generate authorized test events

Use a disposable lab VM. Incorrect-password testing must be performed only under explicit authorization. Run on the Linux target:

```
sudo -k
for i in 1 2 3; do
    echo "===== SOC-LIN-003 failed authentication $i/3 ====="
    sudo -k
    sudo -p "SOC-LIN-003 incorrect password: " -v
done
```

Enter an **incorrect** password when prompted for each test attempt. Depending on PAM/sudo behavior, one invocation can create multiple failure records; the acceptance criterion is **three matching log events**, not three distinct sudo commands. If the authentication prompt permits retries within a single invocation, inspect and count the actual ingested events rather than assuming the loop produces exactly three.

Then invoke a harmless privileged command, entering the **correct** password:

```
sudo -k
sudo /usr/bin/id -u
```

Expected terminal result: `0` (effective UID 0). This independently validates this specific test command's privilege level; a sudo process-start log alone does **not** prove successful command completion.

1.7 7. Validate the detection and investigate

1. In **Discover**, confirm three separate matching `authentication_failure` events and the later sudo `process` event on the same host and account. Ensure the event `@timestamp` values and time-range selector cover the test.
2. In **Security > Rules**, inspect SOC-LIN-003 **Execution results** for a successful run. Allow for the configured scheduling and look-back behavior; do not infer detection latency from a single UI timestamp.
3. In **Security > Alerts**, locate the SOC-LIN-003 alert. Confirm **Medium** severity, risk score **47**, and `ubuntu-soc-target` / `cybersafe` in the reference lab.
4. Select **Open in Timeline**. Validate **three failure events followed by one root-level sudo process event**; inspect the expanded process record for `system.auth.sudo.command: /usr/bin/id -u` and

`system.auth.sudo.user: root`.

5. Record the source-event sequence and test context. Classify the alert as **True Positive — Benign (authorized laboratory testing)**, add an investigation note, and set the workflow status to **Closed**. Keep the rule enabled.

Historical reference: The original investigation generated an alert on **2026-11-05 at 05:23:04.344 (Kibana display time)**. This timestamp is historical evidence, not an expected timestamp for a fresh reproduction.

1.8 8. Acceptance checklist

Test	Pass condition
Collection	System auth data appears in `logs-system.auth-default`
Field mapping	Both EQL event classes and join keys are populated
Rule compilation	Kibana accepts the EQL and rule saves enabled
Execution	Execution result is **Succeeded**
Controlled test	Three matching authentication-failure events precede the sudo command event
Privileged command	`sudo /usr/bin/id -u` prints `0` during the test
Alert	SOC-LIN-003 alert generated with Medium / risk 47
Investigation	Four correlated source records are inspected in Timeline
Disposition	Investigation note entered; alert closed as authorized testing
Evidence	Rule, sequence, alert, and playbook screenshots retained

1.9 9. Evidence and maintained artifacts

The existing repository includes:

- `detection-rules/SOC-LIN-003.yml` — **experimental** Sigma components and chained correlation; parsing passed but executable backend equivalence **not** established.
- `reports/SOC-LIN-003-investigation.md` — original investigation, findings, and limitations.
- `screenshots/05-detection/detection-006-soc-lin-003-rule-overview.png`.
- `screenshots/06-investigations/investigation-012-soc-lin-003-eql-sequence.png`.

- `screenshots/06-investigations/investigation-013-soc-lin-003-correlation-alert.png`.
- `screenshots/06-investigations/investigation-014-soc-lin-003-playbook-a.png`, `-b.png`, `-c.png`.

Version control: Commit the Markdown guide and its PDF generated from the same approved source; avoid separate manual edits to the PDF. Preserve evidence filenames and review all exports for secrets.

1.10 10. Adaptation for training and client environments

The following are **deployment considerations, not production-validated procedures**:

- Replace lab-specific host/user filters and addresses with approved asset scoping, appropriate RBAC, and monitored account coverage.
- Document log retention, clock synchronization, data transport/TLS trust, privilege boundaries, incident severity policy, and rule ownership.
- Validate parsing and replay against the client's OS versions, sudo/PAM configuration, and agent/integration version before enabling alerts at scale.
- Test legitimate administrative retries, false-positive rate, schedule overlap, and duplicate alerts; consider command completion telemetry from auditd/eBPF where required.
- Avoid treating `event.outcome != "failure"` on a sudo process-start record as proof of execution success.
- The native EQL sequence enforces a single ten-minute maximum span. The **experimental Sigma chained correlation does not have proven equivalent semantics** and must not replace it without backend-specific testing.

1.11 11. Source and verification status

Established from the completed SOC-LIN-003 investigation and repository: tested EQL, rule settings, observed event fields, benign test command and UID result, alert, investigation status, and filenames. The guide's consolidated step order was assembled from those verified implementation components; **a fresh start-to-finish execution of this written guide has not yet been performed**. The base infrastructure installation is deliberately documented elsewhere.

Further reading: MITRE T1548.003 · Elastic Security documentation